Finance, cash drawers, expenses and treasury: review and plan of action

Prepared: 8 September 2026. **Package:** FIN. **Status:** SOURCE_REVIEW_AND_FOCUSED_VERIFICATION; implementation not started by this run.

1. Assessment and scope

This is a source review and focused local verification, not a full runtime certification. Database clients in the selected tests are mocked or injected. No deployed database, authenticated browser, live provider, production telemetry, restore rehearsal or qualified statutory approval was inspected in this run. Unexecuted scenarios below are acceptance requirements, not test results. No application code, migration, business record or deployment is changed by this report.

Accountable roles: Finance engineering and treasury controller. **Catalog coverage:** finance, cash_drawer

Selected verification: 3 passed, 0 failed in the selected suite. Test source. This package owns or consumes PM-FIN-001, PM-ANA-001, PM-CACHE-001.

The highest-risk review questions are whole-business totals must not come from capped table rows; distinguish cash movement, order revenue and posted earnings; tie transfer pairs without duplicating bank settlement.

2. Source and architecture map

The source inventory contains 34 matching files, including tests and supporting files. 6 sources were hashed and indexed for targeted review. Prefix inventory counts are discovery aids, not reviewed-file counts. The full list and source hashes are in the source manifest.

Layer	Current source/navigation anchor	Evidence boundary
services	services/finance/finance-dashboard.service.ts	1070 lines; SHA-256 b378831e007f…
hooks	hooks/finance/useFinanceDashboard.ts	28 lines; SHA-256 7b238594b82f…
actions	actions/finance/finance-dashboard.actions.ts	32 lines; SHA-256 8722b61768cd…
actions	actions/finance/customer-settlement.actions.ts	93 lines; SHA-256 2b343e659e5e…
components	components/finance/PaymentReconciliationWorkbench.tsx	1926 lines; SHA-256 ff29e526bcdd…
components	components/finance/FinanceSpecializedLedgerSurfaces.tsx	1643 lines; SHA-256 dc649558fdaf…

Route/API paths must be expanded from callers; absence from the selected prefix inventory is not a declaration that none exist.

Data declarations

Schema model	Selected declared storage/relationship facts
CashDrawer	currentBalance Decimal @default(0) @db.Decimal(14, 2); expectedBalance Decimal @default(0) @db.Decimal(14, 2); @@index([locationId])

Schema model	Selected declared storage/relationship facts
CashDrawerTransaction	amount Decimal @db.Decimal(14, 2); balanceBefore Decimal @db.Decimal(14, 2); balanceAfter Decimal @db.Decimal(14, 2)
Expense	amount Decimal @db.Decimal(14, 2); @@unique([organizationId, expenseNumber]); @@index([organizationId, expenseDate]) // hot: monthly P&L
ExpenseCategory	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, nameEn]); @@index([organizationId])
Payment	amount Decimal @db.Decimal(14, 2); cashTendered Decimal? @db.Decimal(14, 2); changeGiven Decimal? @db.Decimal(14, 2)
CustomerLedgerEntry	customer Customer @relation(fields: [customerId], references: [id], onDelete: Cascade); debit Decimal @default(0) @db.Decimal(14, 2); credit Decimal @default(0) @db.Decimal(14, 2)
SupplierLedgerEntry	supplier Supplier @relation(fields: [supplierId], references: [id], onDelete: Cascade); debit Decimal @default(0) @db.Decimal(14, 2); credit Decimal @default(0) @db.Decimal(14, 2)

These are schema declarations. Exact migration application, actual constraints/indexes, row populations, query plans and direct-write bypasses remain unverified. See the platform package for migration/restore ownership.

Workflow trace and handoffs

The diagram is the review boundary and required end-to-end trace. Source links and selected tests substantiate only the portions described in this report; it does not claim every edge was exercised.

```
flowchart LR
  A["Business trigger / source"] --> B["Fresh tenant and role authority"]
  B --> C["FIN: owning domain service"]
  C --> D["Transaction and source evidence"]
  D --> E["Event / dependent workflow"]
  D --> F["Read model / query scope"]
  F --> G["UI / export / recovery"]
  E --> H["Reconciliation / assurance"]
```

Workflow	Expected outcome	Evidence disposition
FIN-FLOW-1	Reconcile cash opening, receipts, disbursements, refunds and counted closing	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified
FIN-FLOW-2	Review expenses and internal cash transfers with source evidence	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified
FIN-FLOW-3	Present cash, aging and profitability with declared population, currency and basis	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified

Integration contracts: IAM — Identity, tenant access, settings and administration; PAY — Providers, statements, matching and suspense; POS — POS sales, refunds and shifts; EVT — Events, recovery, migrations and platform operations. These identify validation/ownership interfaces, not permission to duplicate their implementations. Accounting remains owned by the existing accounting roadmap.

Graph navigation: graph_actions.json node `finance_customer_settlement_actions_ts`, community 110 (L1); graph_actions.json node `finance_customer_settlement_actions_reversecustomersettlementaction`, community 110 (L56); graph_components.json node `finance_financespecializedledgersurfaces_tsx`, community 3 (L1); graph_components.json node `finance_financespecializedledgersurfaces_inputdate`, community 3 (L97); graph_hooks.json node `finance_usefinancedashboard_ts`, community 39 (L1); graph_hooks.json node `finance_usefinancedashboard_usefinancedashboard`, community 39 (L20). Graph extracts predate this review and are not runtime proof.

3. Controls to preserve

The following assertions passed against mocks/injected clients in this run. Preserve their contracts while extending validation; test names are not broader certification claims.

- finance dashboard payroll forecast proof surfaces authoritative aggregate payroll forecast proof for finance cash planning.
- finance dashboard payroll forecast proof keeps blocked declaration proof specific and routes finance action to payroll declarations.
- finance dashboard payroll forecast proof withholds payroll forecast proof before snapshot reads when payroll module is not entitled.

4. Findings, limitations and risks

PM-FIN-001 — Finance summary aggregates are bounded by display-oriented row caps

CONFIRMED_SOURCE_DEFECT · P1. Confidence: High for source behavior; affected tenant population unmeasured. Likelihood: Conditional on population exceeding the caps; prevalence unknown.

Evidence: services/finance/finance-dashboard.service.ts:568; line 697; line 742; line 766.

Trigger: More than 250 eligible orders or 100 active counterparties in the requested scope.

Expected: Summary totals and counts represent the complete declared population; paginated detail rows have an independent query.

Observed: The service fetches capped order/customer/supplier sets and derives revenue and receivable/payable summary values from those arrays. The selected finance test covers payroll forecast proof, not overflow populations.

Cause / uncertainty: Summary computation and display data reuse the same bounded read arrays.

Consequences: Cash planning, aging, working capital and profitability can omit obligations or revenue and lead operators to incorrect decisions. No monetary loss or production incident was measured.

Existing mitigation: Organization filters and some explicit payroll proof states exist; they do not restore omitted rows.

Correction: Use scoped decimal database aggregates and separate detail pagination; bind totals to a consistent snapshot and explicit operational/accounting basis.

Acceptance: Fixtures with 251 orders and 101 customers/suppliers retain complete totals; pagination does not alter KPIs; export and detail reconcile.

Owner / estimate: Finance/data engineering with treasury controller; 3–6 engineering days after the metric contract; production data investigation separately sized. Estimates are planning judgments, not booked capacity.

Data and rollout: Recompute impacted views and identify exported/relied-upon reports; do not manufacture journal corrections for a read-model defect.

Related earlier work: ACC-014, ACR-21

PM-ANA-001 — Business Pulse includes draft orders and defaults the displayed currency to XAF

CONFIRMED_SOURCE_DEFECT · P1. Confidence: High for query/composition path. Likelihood: Conditional on draft/non-XAF/time-boundary usage; observed tenant frequency unknown.

Evidence: services/analytics/sales-analytics.service.ts:165; line 143; line 631; line 647.

Trigger: An eligible location contains a draft order, or a non-XAF organization opens Business Pulse.

Expected: Recognized sales, currency and business-day boundaries come from reviewed tenant/source policy; drafts are not described as completed sales.

Observed: The sales read excludes only CANCELLED, sums the remaining order totals, and the runtime Business Pulse caller omits currency when composing output; composition defaults to XAF. Date boundaries also use server-local start/end-of-day helpers.

Cause / uncertainty: Generic order aggregation is reused for an authoritative-sounding sales KPI and runtime context is incomplete.

Consequences: Operators may treat unfinalized demand as revenue or read the wrong currency, propagating incorrect signals into priorities and management decisions.

Existing mitigation: A blocked-state composer and composition test exist; the selected test supplies precomputed summary values and does not exercise source population or tenant currency resolution.

Correction: Reuse the existing analytical context work; define recognized event/returns/cutoff policy, resolve tenant currency and add source-to-UI fixtures.

Acceptance: Completed 100 plus draft 900 yields recognized sales 100 under the agreed policy; non-XAF and local-midnight fixtures retain correct labels and periods.

Owner / estimate: Analytics engineering and metric owner; 3–6 engineering days after policy agreement. Estimates are planning judgments, not booked capacity.

Data and rollout: Review affected dashboards/exports and downstream signals; retain source transactions unchanged.

Related earlier work: STQ-RM-001, historical F1

PM-CACHE-001 — Several sensitive query families omit tenant or actor identity

CREDIBLE_RISK_REQUIRES_RUNTIME_VALIDATION · P1. Confidence: High for missing key dimensions; cross-session disclosure not demonstrated. Likelihood: Depends on client lifetime and identity-transition behavior; unmeasured.

Evidence: hooks/payments/usePaymentReconciliationDashboard.ts:19; hooks/payroll/usePayrollWorkbench.ts:16; hooks/finance/useFinanceDashboard.ts:7; hooks/posHooks/useOfflineSync.ts:75; lib/providers/query-provider.tsx:14.

Trigger: Organization, actor, permissions or entitlements change while the QueryClient survives.

Expected: Scope-changing transitions cannot render old protected results; result-changing scope belongs in cache identity with cancellation/removal where necessary.

Observed: Payment and payroll keys use fixed prefixes (and limits/IDs); finance/offline keys include filters but no explicit tenant/actor. QueryProvider creates one client with useState. This review did not execute every identity-change path or establish whether navigation remounts/clears it.

Cause / uncertainty: Server-inferred authority is not represented explicitly in these client keys.

Consequences: Stale financial or personnel data may be shown in the wrong context if the client survives. Severity justifies early validation, but this is not a confirmed disclosure incident.

Existing mitigation: Server actions retain authorization and some keys have location/run filters; full reloads could clear caches but are not a complete demonstrated contract.

Correction: Trace every switch/logout/revocation path, then centralize scoped keys and query cancellation/removal; avoid retaining previous protected data across authority changes.

Acceptance: Same-browser two-tenant/actor tests show no old values during loading, errors or revocation; all impacted views refresh after writes.

Owner / estimate: Shared frontend/IAM owner plus affected module owners; 2–3 days to validate; 3–7 engineering days if shared lifecycle correction is required. Estimates are planning judgments, not booked capacity.

Data and rollout: No data mutation required; assess exposure only if runtime reproduction identifies it.

Related earlier work: ACC-010, ACR-22

Additional module scenarios still requiring verification

- **FIN-VERIFY-1:** Whole-business totals must not come from capped table rows. Owner: Finance engineering and treasury controller. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **FIN-VERIFY-2:** Distinguish cash movement, order revenue and posted earnings. Owner: Finance engineering and treasury controller. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **FIN-VERIFY-3:** Tie transfer pairs without duplicating bank settlement. Owner: Finance engineering and treasury controller. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.

5. Layer and reviewer dispositions

Lens	Current disposition and remaining proof
Architecture, backend and integrations	Sources/call boundaries inventoried; selected service assertions above. Trace alternate entry points and every handoff before whole-domain approval.

Lens	Current disposition and remaining proof
Database, migration and integrity	Named schema models indexed. Deployment, tenant-consistent foreign keys, locking, rollback, scale and backfill/restore not verified.
IAM, privacy, fraud and controls	Apply direct denied-no-read/no-write, role revocation, maker-checker and export redaction tests. A server guard or hidden button alone is insufficient.
Frontend, queries and design system	Client/action entry above inspected statically where present; cache identity, mutation effects and source truth must be traced into actual screens.
UX, accessibility, EN/FR and content	Authenticated role tasks, keyboard/focus, mobile and localized state behavior not executed; no accessibility claim.
Product and business process	Three explicit workflows and supported-scope decisions above; measure task completion and support burden before redesign.
Accounting and financial controls	Source/amount/quantity/period/currency tie-outs and correction ownership apply; reuse ACC/ACR controls.
Statutory and country review	No new statutory interpretation is made. Escalate any discovered country-specific output to CMP/qualified review.
QA and release	3 passed, 0 failed in the selected suite. linked test source. Unit results do not replace integrated evidence.
SRE, performance and cost	No latency/load/restore measurements; establish bounded reads, worker age/error metrics, alerts, retries and support ownership before rollout.
AI and agent authority	AI model behavior is not applicable unless a connected agent consumes this module; review that access contract without adding AI features.
Packaging, billing and operations	Confirm actual catalog/entitlement scope and mandatory retained obligations. Provider billing, adoption and customer outcomes are unverified.

6. Ordered execution plan

PM-FIN-01 — Bind current scope, owners and candidate

Status: READY. **Owner:** Finance engineering and treasury controller. **Effort:** 1–2 reviewer days.

Deliverable: Confirm every listed workflow, supported variant and relevant prior ACC/ACR or STQ-RM item; hash current sources, map entry points and name a domain reviewer.

Acceptance: All material paths have active/legacy/deferred status; no existing change is overwritten.

Prerequisite: Candidate/owner availability; existing historical evidence is a lead..

PM-FIN-02 — Reproduce priority risks and freeze contracts

Status: PLANNED. **Owner:** Finance engineering and treasury controller. **Effort:** 2–4 reviewer/QA days; isolated environments may extend elapsed time.

Deliverable: Whole-business totals must not come from capped table rows; Distinguish cash movement, order revenue and posted earnings; Tie transfer pairs without duplicating bank settlement. Reproduce all linked findings before prescribing data repair.

Acceptance: A scenario ledger records expected/observed behavior, source IDs, denied side effects and remaining blockers.

Prerequisite: PM-FIN-01.

PM-FIN-03 — Implement verified corrections and investigate affected data

Status: CONDITIONAL_ON_CONFIRMED_FINDINGS. **Owner:** Finance engineering and treasury controller. **Effort:** Use linked finding estimates; otherwise estimate after diagnosis.

Deliverable: Correct the smallest owning boundary; preserve domain history, shared controls and public contracts. Investigate historical impact separately and design reversible repair only if needed.

Acceptance: Focused regression, cross-module tie-out and review prove the correction; no speculative implementation or silent historical rewrite.

Prerequisite: PM-FIN-02. If no defect is confirmed, record a reviewed no-change disposition; this satisfies the decision step without speculative work.

PM-FIN-04 — Verify integrated release and controlled rollout

Status: PLANNED. **Owner:** Finance engineering and treasury controller. **Effort:** 2–3 reviewer/QA days plus the real operational cycle.

Deliverable: Run isolated DB failure/concurrency scenarios, authenticated role/locale/cache tests, representative performance/export checks and recovery rehearsal. Pilot the agreed supported scope.

Acceptance: No unexplained material mismatch, unauthorized effect or stale evidence claim; domain reviewer and operations owner accept scoped results.

Prerequisite: PM-FIN-03.

Existing accounting and enterprise roadmap estimates must be deduplicated: PM findings linked to ACC/ACR or STQ-RM reuse the owning task. Reviewer-day estimates here are not engineering effort for a complete rewrite and must not be summed with the accounting roadmap as if independent.

7. Data correction, rollout and completion

Investigate exposure using source IDs, time/currency scope, counts and reconciled totals before proposing any repair. Preserve original records, hashes and exports; use reviewed corrective transactions or versioned migration only where necessary. Rehearse backup/restore and rollback in a disposable environment. Code correction and historical reconciliation are separate acceptance items. A query/display issue alone does not justify rewriting financial history.

Start with an agreed eligible pilot and observe a complete relevant cycle (sale/refund/shift; receiving/invoice/payment; payroll period; or close). Stop expansion on unauthorized effects, unexplained material mismatches, duplicate effects or stale proof. Record incident owner, recovery route and the data needed for investigation. No pilot or release is authorized or completed by this document.

Completion requires disposition for every workflow, current-source evidence for each significant claim, tested or explicit blocked failure scenarios, domain-reviewed corrective work and an understood operational handoff. The tailored audit prompt provides the full repeatable execution brief.

8. Evidence and provenance

Commit: `a05a41ef66cd5d98fd69ae3df18225795f912232` ; branch: `codex/migration-control-plane-release-2026-08-29` . Initial capture: 2026-09-08T14:41:48.494Z. Dirty workspace preserved; claims bind to file hashes, not clean HEAD. Unit command: 2026-09-08T14:43:08.844Z to 2026-09-08T14:44:14.458Z; exit 1. See exact command, assertion results, test log and shared evidence index. Historical reports were used for navigation and work deduplication; their earlier pass counts are not included in this run.